

OMNI-CHANEL CHAT CRM BOOKING KOC/KOL

M V P B A C K E N D
& S Y S T E M D E S I G N

N G U Y E N T I E N D A T

ARCHITECTURE

MODULAR MONOLITH

BACKEND MODULES

Auth & RBAC

KOC CRM

Channel Connector

Conversation Inbox

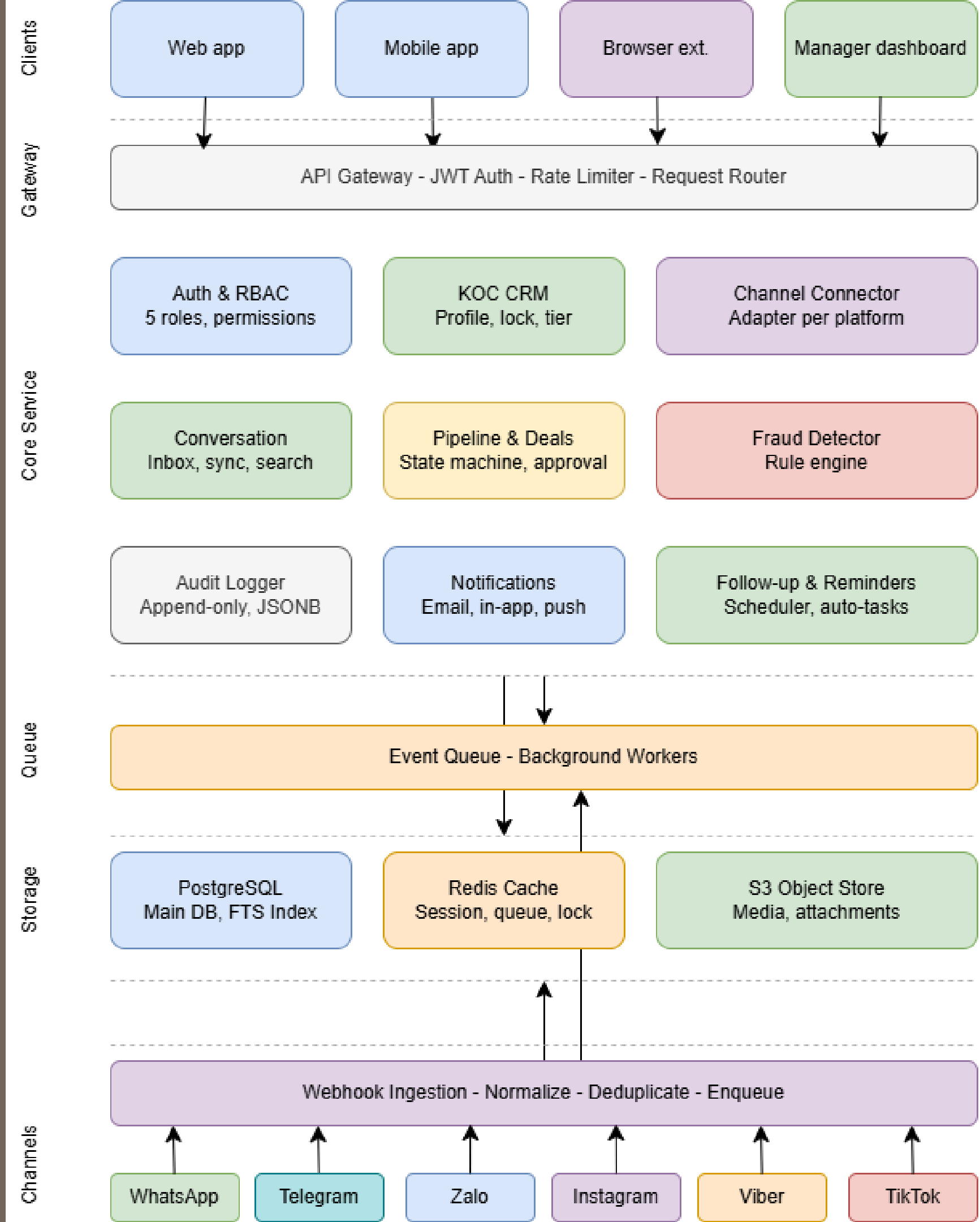
Pipeline/Deals

Fraud Detector

Audit Logger

Notifications

Deploy đơn giản, dễ debug.
Microservices gây overhead
không cần thiết ở MVP.
Module boundaries được thiết
kế sẵn để tách khi cần scale.



CHANNEL INTEGRATION STRTEGY

WhatsApp - Cloud API (Meta)

Method: REST/Graph API
Auth: System User Access Token
Verify: HMAC-SHA256 hub.challenge
Note: per-message price

Telegram - Bot API

Method: set webhook + secret token
Auth:X-Telegram-Bot-API-Secret-Token
Verify: HMAC-SHA256 header check
Note: Port 443/80/88/8443 only

Zalo - Official Account API

Method: OA API + webhook (POS)
Auth: OA Access Token (OAuth v4)
Verify: OA Secret Key signature
Note: Approval 1-7 days

Browser Extension

Method: Content script inject DOM observer → Capture messages → POST to backend via HTTPS
Auth:Company JWT token embedded in extension, deploy via Chrome Enterprise Policy
Security: No silent capture, notify Booker, create integration webhook event record

Instagram - Messaging API

Method: REST/Graph API
Auth: Page Access Token (OAuth)
Verify: hub.verify_token + challenge
Note: App review 1-4 weeks

Viber - Bot API (Rakuten)

Method: set webhook + event types
Auth: X-Viber-Auth-Token
Verify: HMAC-SHA256 content-sig
Note: Commercial terms from 2024

Tiktok - Business Messaging API

Method: Business API
Auth: Advertiser OAuth flow
Limit: 10 msg / 48 window

DATABASE DESIGN

users		
id	UUID	
email	VARCHAR(255)	NN
password_hash	VARCHAR(255)	NN
full_name	VARCHAR(255)	
role_id	UUID	NN
is_active	BOOLEAN	NN
last_login_at	TIMESTAMPZ	
created_at	TIMESTAMPZ	NN
updated_at	TIMESTAMPZ	NN

roles		
id	UUID	
name	VARCHAR(60)	NN
permissions	JSONB	NN
description	TEXT	
created_at	TIMESTAMPZ	NN
updated_at	TIMESTAMPZ	NN

koc_profiles		
id	UUID	
name	VARCHAR(255)	NN
alias	VARCHAR(255)	
tier	CHAR(1)	NN
follower_count	BIGINT	
primary_platform	platform_type	E
benchmark_price_min	NUMERIC(15,2)	
benchmark_price_max	NUMERIC(15,2)	
notes	TEXT	
locked_by	UUID	
locked_at	TIMESTAMPZ	
is_active	BOOLEAN	NN
created_by	UUID	
created_at	TIMESTAMPZ	NN
updated_at	TIMESTAMPZ	NN

messages		
id	UUID	
conversation_id	UUID	NN
external_message_id	VARCHAR(255)	NN
platform	platform_type	E NN
direction	CHAR(3)	NN
sender_external_id	VARCHAR(255)	
content_type	content_type	E NN
content	TEXT	
media_url	TEXT	
s3_key	TEXT	
raw_payload	JSONB	
sent_at	TIMESTAMPZ	NN
is_deleted	BOOLEAN	NN
deleted_by	UUID	
deleted_at	TIMESTAMPZ	
is_edited	BOOLEAN	NN
edited_at	TIMESTAMPZ	
created_at	TIMESTAMPZ	NN

pipeline_status_logs		
id	UUID	
conversation_id	UUID	NN
from_status	pipeline_status	E
to_status	pipeline_status	E NN
changed_by	UUID	
change_reason	TEXT	
changed_at	TIMESTAMPZ	NN

follow_up_tasks		
id	UUID	
conversation_id	UUID	NN
assignee_id	UUID	NN
created_by	UUID	
task_type	task_type	E NN
title	VARCHAR(500)	NN
description	TEXT	
due_at	TIMESTAMPZ	NN
status	task_status	E NN
snoozed_until	TIMESTAMPZ	
completed_at	TIMESTAMPZ	
created_at	TIMESTAMPZ	NN
updated_at	TIMESTAMPZ	NN

audit_logs		
id	UUID	
actor_id	UUID	NN
action_type	VARCHAR(80)	NN
entity_type	VARCHAR(60)	NN
entity_id	UUID	NN
before_state	JSONB	
after_state	JSONB	
ip_address	INET	
user_agent	TEXT	
session_id	VARCHAR(255)	
occurred_at	TIMESTAMPZ	NN

conversations		
id	UUID	
koc_profile_id	UUID	NN
booker_id	UUID	NN
platform	platform_type	E NN
external_conv_id	VARCHAR(255)	
pipeline_status	pipeline_status	E NN
last_message_at	TIMESTAMPZ	
last_message_preview	TEXT	
is_archived	BOOLEAN	NN
created_at	TIMESTAMPZ	NN
updated_at	TIMESTAMPZ	NN

booking_deals		
id	UUID	
conversation_id	UUID	NN
koc_profile_id	UUID	NN
booker_id	UUID	NN
campaign_name	VARCHAR(500)	
agreed_price	NUMERIC(15,2)	
currency	CHAR(3)	NN
deal_terms	TEXT	
approval_status	approval_status	E NN
evidence_msg_ids	UUID[]	
approved_by	UUID	
approved_at	TIMESTAMPZ	
rejection_reason	TEXT	
payment_status	VARCHAR(60)	
payment_confirmed_at	TIMESTAMPZ	
created_at	TIMESTAMPZ	NN
updated_at	TIMESTAMPZ	NN

channel_accounts		
id	UUID	
koc_profile_id	UUID	NN
platform	platform_type	E NN
external_account_id	VARCHAR(255)	NN
display_name	VARCHAR(255)	
token_encrypted	TEXT	
token_expires_at	TIMESTAMPZ	
status	channel_status	E NN
connected_by	UUID	
connected_at	TIMESTAMPZ	NN
updated_at	TIMESTAMPZ	NN

message_attachments		
id	UUID	
message_id	UUID	NN
file_name	VARCHAR(500)	
file_type	VARCHAR(100)	
file_size_bytes	BIGINT	
s3_key	TEXT	NN
s3_bucket	VARCHAR(255)	NN
uploaded_by	UUID	
uploaded_at	TIMESTAMPZ	NN

approval_requests		
id	UUID	
deal_id	UUID	NN
requested_by	UUID	NN
approver_id	UUID	
status	approval_status	E NN
decision_note	TEXT	
budget_validated	BOOLEAN	
evidence_verified	BOOLEAN	
requested_at	TIMESTAMPZ	NN
decided_at	TIMESTAMPZ	

risk_flags		
id	UUID	
entity_type	VARCHAR(60)	NN
entity_id	UUID	NN
rule_code	VARCHAR(20)	NN
rule_description	TEXT	
risk_score	SMALLINT	NN
triggered_by	JSONB	
status	risk_status	E NN
resolved_by	UUID	
resolved_at	TIMESTAMPZ	
resolution_note	TEXT	
created_at	TIMESTAMPZ	NN

integration_webhook_events		
id	UUID	
platform	platform_type	E NN
event_id	VARCHAR(255)	NN
event_type	VARCHAR(80)	
raw_payload	JSONB	NN
received_at	TIMESTAMPZ	NN
processed_at	TIMESTAMPZ	
status	webhook_status	E NN
error_message	TEXT	
retry_count	SMALLINT	NN
next_retry_at	TIMESTAMPZ	

conversation_participants		
id	UUID	
conversation_id	UUID	NN
user_id	UUID	NN
role	participant_role	E NN
invited_by	UUID	
joined_at	TIMESTAMPZ	NN

DATABASE DESIGN

Map KOC với nhiều channel accounts

koc_profiles ← channel_accounts (1:N).
UNIQUE(platform, external_account_id)
tránh trùng tài khoản.

Tránh Bookers contact trùng KOC

koc_profiles.locked_by FK→users +
locked_at.
Khi Booker mở conversation → lock KOC.
Chỉ Manager mới unlock.

Chống duplicate webhook

messages:
UNIQUE(external_message_id,platform).
INSERT với ON CONFLICT DO NOTHING →
idempotent.

Lưu token/session an toàn

token_encrypted dùng AES-256 với app-
level key (KMS).
Không lưu plain text.
Chỉ decrypt trong memory khi cần.

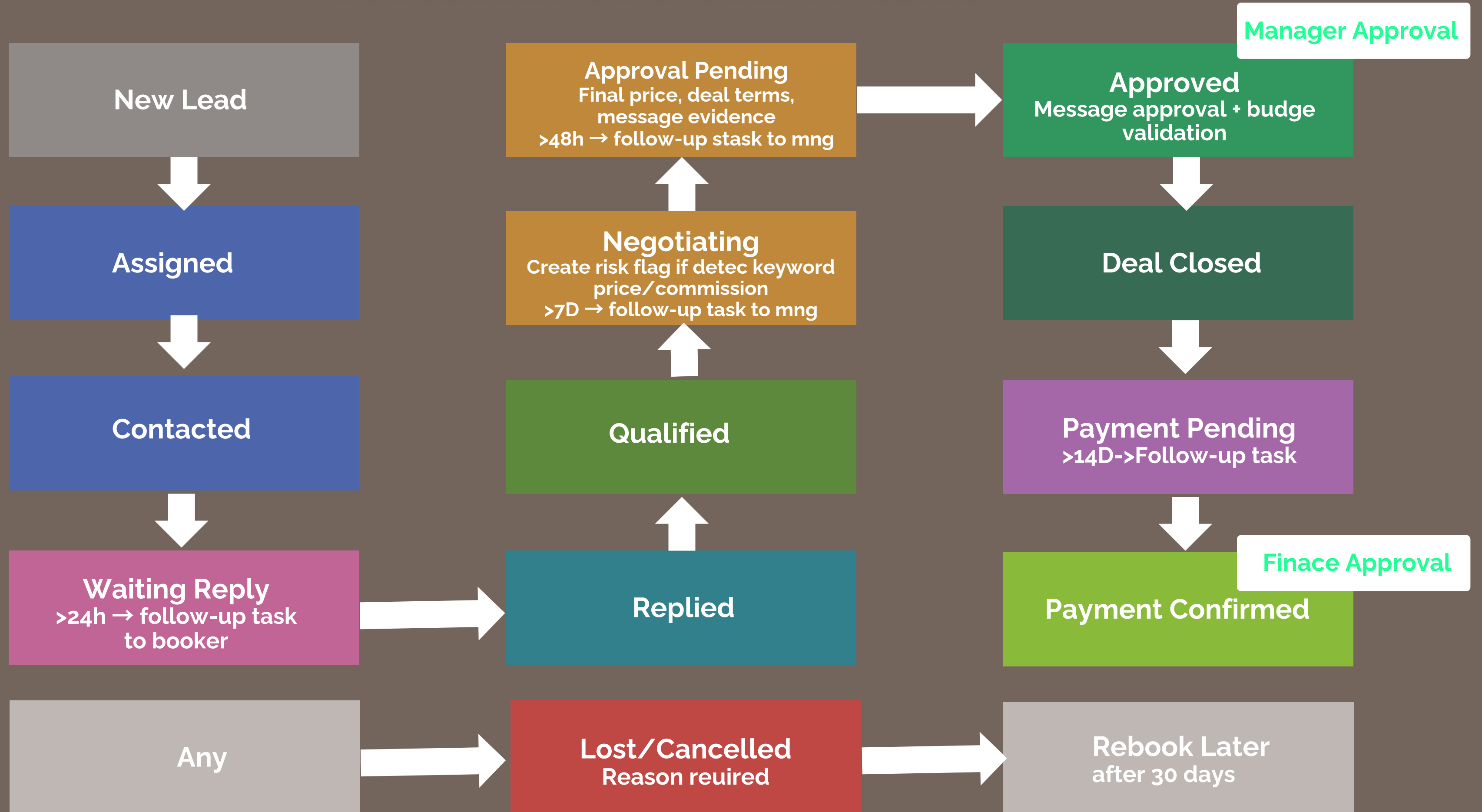
Search conversation

MVP: PostgreSQL full-text search
(tsvector/tsquery) + GIN index.
Scale : migrate sang Elasticsearch khi cần
faceted search.

Audit log strategy

Append-only, NEVER UPDATE/DELETE.
Lưu before/after state (JSONB). Partition
by month.
Tamper-proof: SHA-256 hash chain ở
production.

CONVERSATION & CRM PIPELINE



FRAUD DETECTION

Risk Score: mỗi rule trả về score 1-10. Score >7 → BLOCK + Manager alert. Score 4-7 → Warning + Manager review. Score 1-3 → Flag only.

Message/Deal Event

Rule Evaluator

Risk Score Calc

Action Dispatcher

9

[R01] Deal Closed không có KOC confirmation message

→ BLOCK + Manager review

9

[R03] Keyword: 'ngoài hệ thống', 'bank riêng', 'bonus riêng', 'cash'

→ BLOCK + Alert manager ngay

7

[R05] Nhiều message bị xóa/sửa quanh thời điểm approval

→ Audit flag + warning

7

[R07] Booker close >3 deals/tuần nhưng thiếu chat evidence

→ Account audit flag

7

[R09] Discuss 'payment', 'commission', 'fee', 'discount' ngoài approval workflow

→ Warning + manager notification

8

[R02] Final price khác >20% so với benchmark KOC tier

→ Manager review required

8

[R04] Giá update nhưng không có message nhắc đến giá

→ BLOCK deal update

6

[R06] KOC bị nhiều Booker contact cùng lúc (vi phạm lock policy)

→ Block Booker thứ 2

6

[R08] Deal approval sau khi đã commit với KOC (backward approval)

→ Warning + require review

8

[R10] Booker dùng personal channel ngoài hệ thống: không có message log nhưng vẫn update deal

→ BLOCK deal update + alert

DECREASE FALSE POSITIVE

Whitelist keywords

Allow 'commission' trong context template/contract đã được approved sẵn

Manager override

Manager mark flag là false_positive kèm ghi chú → giảm sensitivity tương lai

Confidence scoring

Chỉ alert khi ≥ 2 rules trigger cùng entity trong một khoảng thời gian

Context window

Check keyword trong context ± 5 messages, không chỉ exact string match

Role-based threshold

Senior Booker có threshold cao hơn dựa trên track record sạch

Feedback loop

False positive được dùng để fine-tune rule weights mỗi sprint review

RBAC & AUDIT

Auth & Channel

- LOGIN_SUCCESS / LOGIN_FAILED
- CHANNEL_CONNECT / DISCONNECT
- TOKEN_REFRESH
- SESSION_EXPIRE

Messaging

- MESSAGE_SENT / RECEIVED
- MESSAGE_EDITED (before/after)
- MESSAGE_DELETED (who, reason)
- MEDIA_UPLOADED

Conversation & KOC

- CONV_OWNER_CHANGE
- KOC_LOCKED / UNLOCKED
- PIPELINE_STATUS_CHANGE
- FOLLOW_UP_CREATED / CLOSED

Deal & Finance

- DEAL_PRICE_UPDATE (before/after)
- APPROVAL_REQUESTED
- APPROVAL_GRANTED / REJECTED
- DEAL_CLOSED

Risk & Security

- RISK_FLAG_CREATED
- RISK_FLAG_RESOLVED
- RISK_FLAG_FALSE_POSITIVE
- ANOMALY_DETECTED

Data & Admin

- EXPORT_CHAT_LOGS (who, scope)
- USER_ROLE_CHANGED
- ADMIN_ACTION
- DATA_DELETE_RESTRICTED

📌 Audit log: append-only (no UPDATE/DELETE) · actor_id + IP + timestamp · before/after JSONB · partition by month · SHA-256 hash chain (tamper-proof ở production)
RBAC should be similar to the table provided in the problem statement

THANK YOU!